

PROJET FIL ROUGE

CAHIER DES CHARGES

Portail Web & Infrastructure multisite

—

Réponse à l'expression des besoins client

Document de conception soumis à validation avant réalisation

Rubrique	Valeur
Intitulé du projet	Fil Rouge — Portail Web et infrastructure multisite (4 sites)
Émetteur	Le chef de projet / l'équipe technique
Destinataire	La cliente (direction) — validation formelle attendue
Nature du document	Cahier des charges fonctionnel et technique (CDC)
Version	1.0
Statut	Proposé — en attente de validation
Validation attendue	Cahier des charges, architecture et maquette

Sommaire

1. Présentation du document
2. Contexte et enjeux
3. Périmètre du projet
4. Exigences fonctionnelles
5. Exigences non fonctionnelles
6. Architecture technique cible
7. Matrice des droits et contrôle d'accès
8. Choix techniques et justifications
9. Maquette du portail Web
10. Sécurité, journalisation et traçabilité
11. Recette et critères d'acceptation
12. Planning prévisionnel et lots
13. Points soumis à validation de la cliente
14. Annexes

1. Présentation du document

1.1 Objet

Ce document constitue la réponse formelle de l'équipe projet à l'expression des besoins transmise par la cliente. Il ne se contente pas de reformuler les attentes exprimées : il précise, arbitre et propose les solutions techniques permettant de les satisfaire, conformément aux demandes explicites formulées dans le document de cadrage.

Le présent cahier des charges couvre trois livrables attendus par la cliente : le **cahier des charges fonctionnel et technique**, une **première proposition d'architecture technique** et une **maquette visuelle du portail Web**. Il constitue le document de référence contractuel : toute fonctionnalité absente de ce document et non validée en cours de projet ne sera pas considérée comme du périmètre.

1.2 Documents de référence

Réf.	Document	Origine	Usage dans ce CDC
R1	Expression des besoins — Portail Web / Infrastructure multisite	Cliente	Base des exigences fonctionnelles (chapitres 1 à 8)
R2	Schéma réseau et plan d'adressage — SITE B	Fourni par la cliente	Base de la segmentation réseau présentée au 6.2
R3	Demande au chef de projet — éléments attendus avant réalisation	Cliente	Structure des livrables du chapitre 13

1.3 Méthode de lecture et conventions

Les exigences sont identifiées par un code unique de la forme **EF-xx** pour les exigences fonctionnelles et **ENF-xx** pour les exigences non fonctionnelles. Chaque exigence porte une priorité et un critère d'acceptation, ce qui permettra de conduire la recette sans ambiguïté.

Niveau	Signification	Conséquence en cas de non-satisfaction
Impérative	Exigence exprimée explicitement par la cliente, non négociable	Refus de recette du lot concerné
Importante	Nécessaire au bon usage du service, arbitrage possible sur la mise en oeuvre	Recette prononcée avec réserve
Souhaitable	Amélioration proposée par l'équipe projet	Consignée en évolution, hors périmètre initial

1.4 Hypothèses de travail et données restant à confirmer

Les éléments ci-dessous n'ont pas pu être confirmés à la rédaction de ce document. Ils sont posés comme hypothèses de travail et doivent être validés ou corrigés par la cliente. **Les chiffres retenus sont volontairement prudents et n'ont aucune valeur contractuelle tant qu'ils ne sont pas validés.**

Tableau 1 — Hypothèses de travail à valider par la cliente.

Code	Hypothèse retenue	Impact si erronée
H1	3 sites	Dimensionnement des liens inter-sites et de la supervision
H2	Effectif global de l'ordre de 150 salariés, répartis de façon inégale entre les quatre sites.	Dimensionnement des hyperviseurs, des licences et des sauvegardes
H3	Seul le plan d'adressage du SITE B a été communiqué.	Révision du plan d'adressage et des règles de filtrage inter-sites
H4	Domaine Active Directory interne de type entreprise.local, à confirmer.	Adaptation de l'authentification, du SSO et des certificats
H5	RPO de 24 heures et RTO de 4 heures pour les services du portail et l'annuaire.	Choix de la stratégie de sauvegarde et de haute disponibilité
H6	Publication Internet limitée au seul flux applicatif HTTPS en 443. Aucun accès direct aux postes, serveurs ou équipements.	Ensemble de l'architecture d'exposition décrite au chapitre 6
H7	Durée de conservation des journaux fixée à 12 mois.	Capacité de stockage du collecteur de journaux
H8	Environnement de virtualisation de type Proxmox VE, sauf contrainte imposée par le formateur.	Choix d'hyperviseur, de sauvegarde et d'orchestration

À retenir — ces hypothèses sont isolées et identifiables afin de ne pas les confondre avec les exigences exprimées par la cliente. Elles sont reprises au chapitre 13 sous forme de points à arbitrer.

2. Contexte et enjeux

2.1 Contexte

L'organisation dispose de plusieurs sites géographiquement distincts et souhaite se doter d'un service unique d'accès à l'ensemble de ses ressources informatiques. Aujourd'hui, la multiplication des points d'accès, la dispersion des demandes d'assistance et l'absence de supervision centralisée rendent le pilotage difficile et la traçabilité incomplète.

Le projet consiste donc à concevoir et réaliser un **portail Web unique**, adossé à une **infrastructure multisite segmentée**, permettant à chaque salarié d'accéder uniquement aux ressources qui le concernent, et à l'équipe technique de disposer d'une vision consolidée de l'état du système d'information.

2.2 Enjeux identifiés

Enjeu	Description	Traduction dans le projet
Sécurité	Aucune ressource interne ne doit être directement exposée sur Internet.	Exposition unique HTTPS, authentification forte, filtrage strict
Cloisonnement	Un salarié ne doit voir et n'atteindre que son périmètre.	Segmentation VLAN par usage, contrôle d'accès par rôle
Traçabilité	Toute demande, toute intervention et toute modification de droit doit être historisée.	Gestion de tickets et journalisation centralisée
Disponibilité	Les services du portail doivent être accessibles pendant les heures ouvrées.	Supervision, sauvegardes testées, redémarrage automatique
Pilotage	La direction et l'administration doivent disposer d'une vue consolidée.	Tableau de bord administrateur et supervision centralisée
Industrialisation	Le déploiement doit être reproductible et documenté.	Automatisation du déploiement et documentation à jour

2.3 Contraintes structurantes

- Aucun accès RDP ou SSH ne doit être exposé sur Internet.
- Le portail doit gérer au minimum quatre profils : Direction, Administrateur, Technicien et Employé.
- Les opérations sensibles sur le pare-feu, les commutateurs, les hyperviseurs et les serveurs ne doivent pas être exécutables librement depuis une page publique.
- L'outil de supervision et l'outil de gestion des tickets sont au choix de l'équipe projet, sous réserve de justification.
- La maquette du portail doit être validée avant tout début de développement.

3. Périmètre du projet

3.1 Ce qui est inclus

- **Portail Web** : accueil salarié, état des services, espace personnel, accès à la machine virtuelle attribuée, module d'assistance et de tickets, espaces différenciés salarié / technicien / administrateur, documentation.
- **Infrastructure multisite** : adressage IP, découpage en VLAN, routage inter-sites, interconnexion sécurisée des quatre sites.
- **Zone démilitarisée (DMZ)** : hébergement des composants exposés à Internet, publication applicative unique en HTTPS.
- **Accès distant sécurisé** : solution d'accès aux postes virtuels sans exposition des protocoles d'administration.
- **Gestion des identités et des droits** : annuaire, profils, matrice des droits, procédure de réinitialisation de mot de passe.
- **Gestion de parc et d'assistance** : outil de ticketing, suivi des demandes, historisation des interventions.
- **Supervision et sauvegarde** : supervision centralisée de l'infrastructure, sauvegardes et tests de restauration.
- **Documentation et maquette** : maquette visuelle du portail, documentation d'exploitation et procédures.

3.2 Ce qui est exclu

- La refonte du système d'information métier existant et de ses applications.
- Le déploiement des postes de travail physiques et des périphériques utilisateurs.
- La fourniture des équipements réseau, des serveurs physiques et des licences tierces.
- La reprise de données historiques issues d'un éventuel outil de ticketing précédent, sauf demande explicite ultérieure.
- Le maintien en condition opérationnelle après la période de garantie prévue au planning.

3.3 Acteurs et responsabilités

Acteur	Rôle dans le projet	Attentes vis-à-vis du dispositif
La cliente / direction	Valide le cahier des charges, l'architecture et la maquette	Vue consolidée, lisibilité, tableau de bord de synthèse
Chef de projet	Pilote, arbitre et porte la conception technique	Choix techniques justifiés, planning tenu
Administrateur global	Supervise les quatre sites et les opérations sensibles	Droits étendus, actions tracées, aucune exposition publique
Administrateur d'agence	Gère son site uniquement	Droits restreints à son périmètre, sans action sur le coeur inter-sites
Technicien support	Traite les demandes et intervient sur les équipements	Accès aux outils de diagnostic et de support
Employé	Utilise ses ressources et formule ses demandes	Accès simple, sûr et limité à son profil de droits

4. Exigences fonctionnelles

Ce chapitre reprend l'intégralité des besoins exprimés par la cliente et les traduit en exigences vérifiables. Chaque exigence porte un identifiant unique, une priorité et un critère d'acceptation utilisable tel quel en recette.

4.1 Accueil et état des services (chapitre 1 des besoins)

Id	Exigence	Prio.	Critère d'acceptation
EF-01	L'accueil salarié affiche les annonces internes importantes ainsi qu'un état simple des services auxquels le salarié a accès.	Impérative	Un salarié connecté voit au moins une annonce publiée par un administrateur et l'état de chacun des services de son périmètre.
EF-02	Le salarié visualise uniquement les services qui le concernent, sur la base de son profil et de ses droits.	Impérative	Un compte Employé n'affiche ni les services d'administration, ni l'état des équipements réseau.
EF-03	L'administrateur dispose d'un tableau de bord global : état des sites, serveurs, machines virtuelles, accès VPN et principales alertes.	Impérative	Le tableau de bord présente les quatre sites et remonte au moins une alerte de supervision active.
EF-04	La publication d'annonces internes est réservée aux profils autorisés, avec date de publication et date de fin d'affichage.	Importante	Un compte Employé ne dispose d'aucun contrôle de création ou de modification d'annonce.

4.2 Profil utilisateur et gestion des mots de passe (chapitre 2 des besoins)

Id	Exigence	Prio.	Critère d'acceptation
EF-05	Le profil salarié contient au minimum : nom, prénom, adresse e-mail professionnelle, agence, fonction ou rôle, et éventuellement une photo.	Impérative	Les cinq champs obligatoires sont présents et alimentés depuis l'annuaire ; la photo est facultative.
EF-06	Le salarié peut modifier sa photo ainsi que certaines informations personnelles non sensibles.	Impérative	La modification d'une information non sensible est possible ; les champs sensibles sont refusés en écriture.
EF-07	Le salarié ne peut en aucun cas modifier lui-même son rôle, son agence ou ses droits.	Impérative	Toute tentative de modification forcée de ces champs est rejetée côté serveur et journalisée, indépendamment du contrôle d'affichage.
EF-08	En cas d'oubli de mot de passe, le salarié peut effectuer une demande de réinitialisation depuis le portail.	Impérative	Un formulaire de demande génère un ticket horodaté avec identité du demandeur et statut de traitement.
EF-09	L'administrateur autorisé traite cette demande	Impérative	La procédure est décrite en

Id	Exigence	Prio.	Critère d'acceptation
	et procède à la réinitialisation selon une procédure sécurisée et traçable.		documentation, l'action est associée au ticket et l'identité du valideur est historisée.
EF-10	La vérification d'identité du demandeur avant réinitialisation est obligatoire et formalisée.	Importante	Le dossier de procédure précise le canal de vérification d'identité et cette étape est enregistrée dans le ticket.

4.3 Ressources et droits d'accès (chapitre 3 des besoins)

Les ressources doivent être accessibles en fonction du profil de l'utilisateur et de ses droits. Les quatre profils imposés sont Direction, Administrateur, Technicien et Employé. La matrice complète est fournie au chapitre 7.

Id	Exigence	Prio.	Critère d'acceptation
EF-11	L'accès à chaque ressource est conditionné par le profil de l'utilisateur et ses droits effectifs.	Impérative	Le contrôle est réalisé côté serveur ; la modification de l'URL ne donne pas accès à une ressource interdite.
EF-12	Au minimum quatre profils sont gérés : Direction, Administrateur, Technicien, Employé.	Impérative	Les quatre profils existent dans l'annuaire et sont exploitables par le portail.
EF-13	Un Employé n'accède à aucune fonction d'administration.	Impérative	Aucune route d'administration n'est accessible à un compte Employé, y compris par appel direct à l'API.
EF-14	Un Technicien accède aux outils nécessaires au support et au diagnostic.	Impérative	Le Technicien accède au module d'assistance, à l'inventaire et à la supervision en lecture sur son périmètre.
EF-15	Un Administrateur dispose de droits plus importants sur l'infrastructure.	Impérative	Les fonctions de gestion des machines virtuelles, des sauvegardes et des utilisateurs sont accessibles selon son périmètre.
EF-16	Une matrice des droits est livrée et précise les ressources accessibles pour chaque profil.	Impérative	La matrice du chapitre 7 est validée par la cliente et sert de référence en recette.

4.4 Machines virtuelles et travail à distance (chapitre 4 des besoins)

C'est le point le plus sensible du projet : le document de cadrage demande explicitement une architecture permettant ce fonctionnement **sans exposer directement RDP ou SSH sur Internet**. La réponse technique est détaillée au chapitre 6.4.

Id	Exigence	Prio.	Critère d'acceptation
EF-17	Chaque salarié autorisé au travail à distance dispose d'un poste de travail virtuel attribué personnellement.	Impérative	Un utilisateur n'accède qu'à sa propre machine virtuelle ; toute autre machine est refusée et journalisée.
EF-18	Depuis l'extérieur, la connexion passe par un portail d'accès sécurisé avec authentification et validation par un second facteur (MFA).	Impérative	L'accès sans second facteur valide est refusé avant toute ouverture de session sur la machine virtuelle.
EF-19	Une fois connecté à son poste virtuel, le salarié n'accède qu'aux ressources et services nécessaires à son activité et déjà autorisés pour son profil.	Impérative	Le contrôle est appliqué au niveau réseau et applicatif, et non uniquement par restriction de l'affichage.
EF-20	Le salarié ne peut pas accéder librement aux autres serveurs, machines virtuelles, équipements d'administration ou services internes.	Impérative	Les flux entre la zone des postes virtuels et les autres zones sont refusés par défaut et le refus est journalisé.
EF-21	L'ouverture d'un droit d'accès supplémentaire fait l'objet d'une demande via le portail d'assistance, validée par un administrateur avant ouverture.	Impérative	Aucun droit supplémentaire n'est actif sans validation tracée rattachée à un ticket.
EF-22	Fonctionnellement, le droit est ouvert manuellement par l'administrateur après validation, et non automatiquement.	Importante	Aucune automatisation d'attribution de droit ne contredit la validation humaine préalable.
EF-23	L'ensemble des connexions, demandes et modifications de droits est journalisé et exploitable.	Impérative	Une modification de droit produit une entrée de journal contenant auteur, date, cible et nature du changement.

4.5 Assistance, tickets et suivi des demandes (chapitre 5 des besoins)

Id	Exigence	Prio.	Critère d'acceptation
EF-24	Toutes les demandes des salariés et toutes les interventions des techniciens sont entièrement traçables.	Impérative	Chaque intervention est rattachée à un ticket et à un technicien identifié.
EF-25	Chaque demande comporte au minimum : numéro de ticket, demandeur, agence, date et heure de création, catégorie, description, priorité, technicien en charge et statut.	Impérative	Les neuf champs obligatoires sont présents et non vides sur tout ticket créé.
EF-26	L'historique des actions réalisées est conservé jusqu'à la clôture du ticket, puis archivé.	Impérative	L'historique complet reste consultable après clôture en lecture seule.
EF-27	Il est possible de retrouver qui a effectué l'intervention, quand, sur quel service ou équipement, pour quelle raison et avec quel résultat.	Impérative	Une requête de recherche remonte l'ensemble de ces cinq informations pour un ticket donné.

Id	Exigence	Prio.	Critère d'acceptation
EF-28	Le salarié peut suivre l'avancement de ses propres demandes.	Impérative	Chaque ticket est visible par son demandeur avec statut courant et dernière action réalisée.
EF-29	L'outil retenu est choisi et justifié par l'équipe projet.	Impérative	Le comparatif du chapitre 8 justifie le choix de l'outil de ticketing.

4.6 Périmètre des administrateurs (chapitre 6 des besoins)

Id	Exigence	Prio.	Critère d'acceptation
EF-30	Les droits sont distingués selon les responsabilités : administrateur global, administrateur d'agence, technicien.	Impérative	Un administrateur d'agence ne dispose d'aucun droit effectif sur les autres sites.
EF-31	Un administrateur global supervise les quatre sites.	Impérative	Le compte d'administration globale atteint les quatre sites en supervision et en gestion.
EF-32	Le portail peut présenter les équipements et leur état.	Importante	L'état remonte depuis l'outil de supervision et non depuis une saisie manuelle.
EF-33	Aucune opération sensible sur le pare-feu, les commutateurs, les hyperviseurs ou les serveurs n'est exécutée depuis une page publique.	Impérative	Les actions sensibles sont réalisées via un canal d'administration restreint, sur un réseau dédié, avec session tracée.
EF-34	La solution d'administration gérée depuis le portail est sécurisée et les contrôles d'accès retenus sont justifiés.	Impérative	Le chapitre 7.4 détaille et justifie les contrôles d'accès, y compris pour les actions d'administration.

4.7 Supervision et documentation (chapitre 7 des besoins)

La cliente n'impose pas d'outil mais demande une comparaison des solutions adaptées et une justification du choix. Le comparatif figure au chapitre 8.3.

Id	Exigence	Prio.	Critère d'acceptation
EF-35	La supervision centralisée identifie l'indisponibilité d'un serveur ou d'un équipement.	Impérative	Une coupure simulée d'un serveur génère une alerte dans le délai défini au chapitre 5.
EF-36	La supervision identifie la coupure d'un service Web.	Impérative	L'arrêt volontaire du service Web génère une alerte dédiée.
EF-37	La supervision identifie la coupure d'un accès VPN intersite.	Impérative	La rupture du tunnel inter-sites génère une alerte de niveau élevé.

Id	Exigence	Prio.	Critère d'acceptation
EF-38	La supervision identifie l'indisponibilité d'une machine virtuelle.	Impérative	L'arrêt non planifié d'une machine virtuelle supervisée génère une alerte.
EF-39	La supervision remonte l'utilisation processeur, mémoire et disque.	Impérative	Les trois indicateurs sont historisés et affichés sous forme de graphique.
EF-40	La supervision remonte l'échec d'une sauvegarde.	Impérative	Une sauvegarde en échec génère une alerte et l'état est visible depuis le portail.
EF-41	Le portail permet de consulter les informations utiles concernant l'infrastructure, les sauvegardes, les incidents et la documentation technique.	Impérative	Quatre rubriques distinctes sont accessibles avec des données à jour.
EF-42	L'outil de supervision est choisi et justifié.	Impérative	Le comparatif du chapitre 8.3 justifie le choix retenu.

4.8 Portail Web et maquette (chapitre 8 des besoins)

Id	Exigence	Prio.	Critère d'acceptation
EF-43	Une maquette visuelle du portail est présentée et validée avant tout développement.	Impérative	Procès-verbal de validation de la maquette signé par la cliente avant le démarrage du développement.
EF-44	La maquette couvre au minimum les écrans suivants : Accueil, Connexion, Espace salarié, Mon profil, Mes services, Ma machine virtuelle, Assistance / Tickets, Tableau de bord administrateur, Utilisateurs, Agences, Réseau, VPN, VM, Serveurs, Supervision, Sauvegardes, Documentation.	Impérative	Les dix-sept écrans sont présents dans la maquette livrée.
EF-45	La différence entre espace salarié, espace technicien et espace administrateur est visualisable, avec les fonctionnalités correspondant aux droits de chaque profil.	Impérative	Trois présentations distinctes sont fournies pour un même écran selon le profil connecté.
EF-46	La maquette présente les parcours de navigation et des exemples d'écrans : tableau de bord, création d'un ticket, suivi d'une demande, accès à une machine virtuelle et supervision.	Impérative	Les cinq parcours sont décrits pas à pas dans le document de maquette.

5. Exigences non fonctionnelles

Ces exigences ne sont pas exprimées par la cliente mais conditionnent la qualité et la pérennité du service. Elles constituent des engagements de l'équipe projet.

5.1 Sécurité

Id	Exigence	Niveau
ENF-01	Aucune ressource d'administration n'est joignable directement depuis Internet. La seule publication externe est le flux applicatif HTTPS en 443.	Impérative
ENF-02	Les protocoles d'administration à distance des postes et serveurs (RDP, SSH, VNC) ne sont jamais exposés sur Internet ni publiés par translation d'adresse.	Impérative
ENF-03	L'authentification à distance est renforcée par un second facteur pour tous les profils, sans exception.	Impérative
ENF-04	Le principe du moindre privilège s'applique par défaut : tout flux non explicitement autorisé est refusé.	Impérative
ENF-05	Le contrôle des droits est appliqué côté serveur et côté réseau, jamais uniquement par masquage d'interface.	Impérative
ENF-06	Les actions d'administration sensibles font l'objet d'une double validation et d'une session journalisée.	Importante
ENF-07	Les flux entre zones sont filtrés par un pare-feu dédié ; les sessions entrantes de la zone exposée vers le réseau interne sont refusées par défaut.	Impérative
ENF-08	Les secrets et comptes de service sont gérés de manière centralisée et ne sont pas stockés en clair.	Importante
ENF-09	Les certificats TLS sont valides, renouvelés automatiquement et couvrent les noms publiés.	Importante
ENF-10	L'infrastructure est segmentée par usage et le réseau d'administration est isolé du réseau utilisateur.	Impérative

5.2 Disponibilité, performance et reprise

Id	Exigence	Niveau
ENF-11	Le portail est disponible pendant les heures ouvrées avec un objectif de disponibilité de 99,5 % sur le mois.	Importante
ENF-12	Une alerte de supervision est émise en moins de 5 minutes après la détection d'une indisponibilité.	Impérative
ENF-13	Le temps de réponse du portail reste inférieur à 2 secondes sur les écrans courants en charge nominale.	Importante

Id	Exigence	Niveau
ENF-14	Les composants exposés sont déployés en redondance afin qu'une panne unitaire ne rende pas le service indisponible.	Importante
ENF-15	Les sauvegardes respectent un RPO de 24 heures et un RTO de 4 heures pour le portail et l'annuaire.	Importante
ENF-16	Un test de restauration est réalisé au moins une fois par trimestre et documenté.	Impérative

5.3 Traçabilité, exploitation et maintenabilité

Id	Exigence	Niveau
ENF-17	Toute action d'authentification, de modification de droit et d'administration est journalisée avec horodatage, auteur et adresse source.	Impérative
ENF-18	Les journaux sont centralisés sur un collecteur dédié et conservés 12 mois.	Importante
ENF-19	Les horloges des équipements et serveurs sont synchronisées sur une source de temps commune afin de rendre les journaux exploitables.	Impérative
ENF-20	Le déploiement des composants est automatisé et reproductible à partir d'un dépôt versionné.	Importante
ENF-21	Chaque composant dispose d'une documentation d'installation, d'exploitation et de restauration.	Impérative
ENF-22	La documentation technique est accessible depuis le portail pour les profils habilités.	Importante
ENF-23	Sauvegardes et configurations sont externalisées hors du site principal.	Importante

5.4 Ergonomie et accessibilité

Id	Exigence	Niveau
ENF-24	L'interface est disponible en français et utilisable sans formation préalable pour un salarié.	Importante
ENF-25	La charte graphique est cohérente sur l'ensemble des écrans et respecte des contrastes suffisants.	Souhaitable
ENF-26	L'interface est utilisable sur poste fixe comme sur écran réduit, sans perte de fonctionnalité.	Souhaitable
ENF-27	Les messages d'erreur sont explicites et n'exposent aucune information technique interne.	Impérative

6. Architecture technique cible

6.1 Vue d'ensemble

L'architecture proposée repose sur quatre principes : un réseau segmenté par usage, une zone exposée isolée, un point d'entrée unique pour les accès distants, et une administration qui ne passe jamais par une interface publique.

Tableau 2 — Découpage logique de l'architecture cible.

Zone	Rôle	Contenu	Exposition
Internet	Accès distant des salariés	Navigateur du salarié	Point d'entrée unique HTTPS
Zone exposée (DMZ)	Publication applicative	Reverse proxy / répartiteur, serveurs applicatifs, résolveur DNS	Publication 443 uniquement, depuis la DMZ
Réseau interne	Services internes	Annuaire, supervision, ticketing, sauvegardes, partages	Non exposé, accessible via le portail
Zone des postes virtuels	Travail à distance	Machines virtuelles attribuées nominativement	Accessible uniquement via la passerelle de session
Réseau d'administration	Gestion de l'infrastructure	Accès d'exploitation pare-feu, commutateurs, hyperviseurs	Isolé, jamais publié, accès tracé

Interconnexion des sites

- Chaque site est raccordé au site principal par un **tunnel chiffré de type site à site**, monté entre les pare-feux.
- Le routage inter-sites est porté par les commutateurs de niveau 3 et les pare-feux, avec des règles de filtrage explicites par flux.
- Aucune route par défaut n'est propagée entre sites : seuls les flux nécessaires sont autorisés.
- Les sites secondaires peuvent héberger leurs propres machines virtuelles de travail afin de limiter la latence.

Rôle du site principal

- Hébergement de la zone exposée et des services transverses : portail, annuaire, ticketing, supervision, sauvegardes.
- Concentration des accès distants entrants.
- Point d'administration centrale pour l'administrateur global.

6.2 Segmentation réseau — cas du SITE B (document de référence R2)

Le plan d'adressage ci-dessous reprend la segmentation validée sur le SITE B. La même logique de découpage est appliquée aux autres sites, avec un troisième octet distinct par site. **Seul le SITE B est documenté à ce stade**, les sites A, C et D restent à confirmer (hypothèse H3).

Tableau 3 — Plan d'adressage du SITE B, repris du schéma de référence R2.

Zone	Réseau	Passerelle / interface	Adresses clients ou fixes
------	--------	------------------------	---------------------------

VLAN 10 — Direction	172.16.1.0/27	172.16.1.1	Clients 172.16.1.2 à .30
VLAN 20 — Comptabilité	172.16.1.32/27	172.16.1.33	Clients 172.16.1.34 à .62
VLAN 30 — Wi-Fi / visiteurs	172.16.1.64/27	172.16.1.65	Clients 172.16.1.66 à .94
VLAN 40 — Administration	172.16.1.96/27	172.16.1.97	Clients 172.16.1.98 à .126
VLAN 50 — Serveurs	172.16.1.128/27	172.16.1.129	Fixes 172.16.1.130 à .135
VLAN 99 — Management	172.16.1.160/27	172.16.1.161	Équipements d'administration

Zone exposée du SITE B

Tableau 4 — Détail de la zone exposée du SITE B, repris du schéma de référence R2.

Machine	Adresse	Fonction	Exposition
Serveur Web	172.16.3.70	Accès interne au portail	Aucune publication Internet
DNS interne	172.16.3.71	Résolution interne	Aucune publication Internet
Reverse proxy / répartiteur	172.16.3.72	Point d'entrée applicatif	Seule publication : TCP 443
Serveurs applicatifs	172.16.3.80, .81, .82	Instances applicatives	Joignables uniquement depuis le reverse proxy
Lot d'adresses libre	172.16.3.83 à .126	Extensions futures	Non publié
Réserves et adresses fixes	172.16.3.66 à .79	Équipements et adresses fixes	Non publié

Cette conception est conservée telle quelle : elle satisfait directement l'exigence de non-exposition des protocoles d'administration. Le reverse proxy constitue l'unique point d'entrée et ne dialogue avec les serveurs applicatifs que sur les ports applicatifs strictement nécessaires.

Règles de filtrage de la zone exposée

- Les nouvelles sessions initiées depuis la zone exposée vers le réseau interne sont **refusées**.
- Les retours de session des flux explicitement autorisés sont permis, par suivi d'état.
- Les sorties depuis la zone exposée sont limitées aux flux nécessaires : HTTPS, DNS et synchronisation de temps.
- Les flux à l'intérieur d'un même réseau ne bénéficient d'aucun filtrage implicite : la protection des hôtes relève de chaque machine.
- Aucune traduction d'adresse n'est créée vers les serveurs applicatifs ou le serveur Web interne : seule l'adresse du reverse proxy est publiée.

6.3 Réponse à la demande de la cliente : accès distant sans exposer RDP ou SSH

Exigence de référence : EF-18, EF-19, EF-20 et ENF-02. C'est la demande explicite formulée au chapitre 4 de l'expression des besoins.

Le principe retenu est le suivant : le salarié ne se connecte jamais à sa machine virtuelle. Il se connecte à un service, et c'est ce service qui lui ouvre une session. Le protocole d'administration à distance ne quitte jamais le réseau interne.

Tableau 5 — Chaîne d'accès distant sécurisé retenue.

Étape	Ce qui se passe	Ce qui est exposé sur Internet
1. Accès	Le salarié ouvre l'URL du portail depuis son navigateur. La requête arrive uniquement sur le reverse proxy en TCP 443.	HTTPS uniquement
2. Authentification	Authentification sur l'annuaire, puis validation d'un second facteur. Sans les deux, aucune suite.	Rien de plus
3. Autorisation	Le portail vérifie le profil et recherche la machine virtuelle attribuée nominativement à ce salarié.	Aucun accès direct
4. Session	Le service de passerelle ouvre lui-même la session vers la machine virtuelle, côté réseau interne, sur le port applicatif retenu.	Aucun port RDP ou SSH ouvert
5. Usage	Le salarié manipule son poste virtuel dans une fenêtre du navigateur.	Flux HTTPS de bout en bout
6. Journalisation	Connexion, identité, machine cible, horodatage et durée sont enregistrés.	Non concerné

Trois garanties en découlent, directement opposables aux exigences :

- **Aucun flux RDP, SSH ou VNC n'est publié** : le seul port ouvert depuis Internet est le 443 applicatif (ENF-02).
- **Aucune machine virtuelle n'est joignable directement**, ni depuis Internet, ni depuis les autres réseaux internes : seule la passerelle peut initier la session, sur les ports strictement nécessaires (EF-19, EF-20).
- **La traçabilité est native** : chaque session passe par un point unique qui journalise qui s'est connecté, quand, sur quelle machine et pour combien de temps (EF-23, ENF-17).

À retenir — le portail n'est pas un annuaire de machines qui donne une adresse IP à l'utilisateur. C'est un médiateur : il choisit lui-même la cible, ouvre la session et ne transmet jamais l'information d'adressage au navigateur du salarié.

Second canal pour les besoins d'administration

Pour les profils habilités, un accès distrait distinct est mis en place sous forme de tunnel chiffré avec authentification par facteur, complété par des règles de filtrage rattachées au profil. Ce canal donne accès au réseau d'administration, jamais aux réseaux utilisateurs. Il respecte les exigences EF-33 et EF-34.

6.4 Supervision et sauvegarde de l'infrastructure

- **Supervision** : un serveur central collecte les métriques et les journaux, depuis le site principal, et supervise les quatre sites.

- **Sondes** : agents sur les serveurs Windows et Linux, interrogation réseau des équipements, remontée matérielle des hyperviseurs, et contrôles applicatifs par requête HTTP sur le portail.
- **Contrôle des sauvegardes** : chaque job de sauvegarde remonte son état, ce qui permet de satisfaire EF-40 par alerte et non par consultation manuelle.
- **Alertes** : notification par messagerie, avec escalade vers l'administrateur global en l'absence d'acquiescement.
- **Sauvegarde** : sauvegarde des machines virtuelles et des données avec rétention échelonnée, copie externalisée, et test de restauration trimestriel documenté (ENF-15, ENF-16, ENF-23).

6.5 Haute disponibilité

- Les services exposés sont répartis sur au moins deux instances applicatives derrière le reverse proxy.
- Les serveurs du site principal sont placés sur plusieurs hyperviseurs afin qu'une panne matérielle n'entraîne pas l'arrêt simultané du portail et de l'annuaire.
- Un site secondaire peut reprendre la publication applicative en cas d'indisponibilité prolongée du site principal (ENF-14).

6.6 Matrice des flux (extrait)

Le détail complet figure en annexe C. Le tableau ci-dessous reprend les flux structurants. Tout flux non listé est refusé.

Tableau 6 — Matrice des flux structurants.

Source	Destination	Protocole / port	Décision
Internet	Reverse proxy en zone exposée	TCP 443	Autorisé, seule publication externe
Internet	Tout autre composant	Tout	Refusé et journalisé
Reverse proxy	Serveurs applicatifs	Ports applicatifs retenus uniquement	Autorisé
Zone exposée	Réseau interne	Nouvelles sessions	Refusé par défaut
Zone exposée	Internet	HTTPS, DNS, NTP	Autorisé selon règles
Passerelle de session	Machines virtuelles nominatives	Ports applicatifs	Autorisé, nommément
Postes virtuels	Serveurs internes	Tout hors services autorisés	Refusé par défaut
Réseau d'administration	Équipements, hyperviseurs	Protocoles d'administration chiffrés	Autorisé, restreint aux sources déclarées
Site secondaire	Site principal	Flux applicatifs nécessaires	Autorisé via tunnel chiffré
Réseau utilisateur	Réseau d'administration	Tout	Refusé

7. Matrice des droits et contrôle d'accès

Ce chapitre répond à la demande explicite de la cliente : une matrice des droits précisant les ressources accessibles pour chaque profil, et la justification des contrôles d'accès retenus pour l'administration.

7.1 Définition des profils

Profil	Description	Périmètre géographique
Employé	Tout salarié utilisant les services applicatifs et son poste virtuel.	Ses propres ressources uniquement
Technicien	Assure le support et le diagnostic de premier et second niveau.	Son site de rattachement
Administrateur d'agence	Gère les utilisateurs, machines virtuelles et sauvegardes de son site.	Une seule agence
Administrateur global	Supervise et administre l'ensemble des sites et des composants transverses.	Les quatre sites
Direction	Consulte les indicateurs de synthèse et les annonces internes.	Vue globale en lecture

7.2 Matrice des droits par ressource

Légende : **Accès** désigne un accès complet dans la limite du périmètre du profil, **Lecture** une consultation seule, **Soi** un accès limité à ses propres ressources, **Non** l'absence totale d'accès contrôlée côté serveur.

Tableau 7 — Matrice des droits par ressource et par profil, proposée à la validation de la cliente.

Ressource / fonction	Employé	Technicien	Admin agence	Admin global	Direction
Accueil et annonces	Accès	Accès	Accès	Accès	Accès
État des services	Soi	Son site	Son site	Global	Lecture
Mon profil	Accès	Accès	Accès	Accès	Accès
Modification des informations non sensibles	Soi	Soi	Soi	Soi	Soi
Modification du rôle, de l'agence ou des droits	Non	Non	Selon périmètre	Accès	Non
Demande de réinitialisation de mot de passe	Soi	Soi	Traitement	Traitement	Non
Mes services	Soi	Son site	Son site	Global	Lecture
Ma machine virtuelle	Sa VM	Ses VM	Ses VM	Toutes les VM	Non
Assistance — création de ticket	Soi	Son site	Son site	Global	Soi

Ressource / fonction	Employé	Technicien	Admin agence	Admin global	Direction
Assistance — traitement et affectation	Non	Accès	Accès	Accès	Non
Assistance — consultation des tickets	Soi	Son site	Son site	Global	Lecture
Tableau de bord administrateur	Non	Lecture	Son site	Global	Lecture
Gestion des utilisateurs	Non	Non	Selon périmètre	Accès	Non
Gestion des agences	Non	Non	Non	Accès	Lecture
Inventaire des équipements	Non	Lecture	Son site	Global	Non
Réseau et VLAN	Non	Lecture	Lecture	Accès	Non
Supervision — consultation	Non	Son site	Son site	Global	Lecture
Supervision — acquittement d'alerte	Non	Non	Son site	Global	Non
Sauvegardes — consultation	Non	Lecture	Son site	Global	Non
Sauvegardes — lancement et restauration	Non	Non	Son site	Accès	Non
Gestion des machines virtuelles	Non	Non	Son site	Accès	Non
Pare-feu, commutateurs, hyperviseurs	Non	Non	Non	Accès via canal restreint	Non
Documentation technique	Publique	Accès	Accès	Accès	Lecture
Journal d'audit	Non	Lecture	Son site	Accès	Lecture

7.3 Opérations sensibles et contrôles renforcés

Certaines opérations ne peuvent pas relever d'un simple droit d'accès. Elles sont soumises à des contrôles complémentaires et cumulatifs.

Tableau 8 — Contrôles renforcés sur les opérations sensibles.

Opération sensible	Contrôle supplémentaire requis	Justification
Modification d'une règle de pare-feu	Double validation, session journalisée, aucun accès depuis une page publique	Une erreur coupe l'accès au service ou ouvre un accès non voulu
Modification de configuration d'un commutateur	Accès depuis le réseau d'administration uniquement	Risque de rupture de la segmentation réseau

Opération sensible	Contrôle supplémentaire requis	Justification
Action sur un hyperviseur	Double validation et plan de retour arrière documenté	Impact direct sur plusieurs services hébergés
Restauration de sauvegarde	Validation obligatoire, horodatage, compte rendu	Risque d'écrasement de données récentes
Attribution d'un droit supplémentaire	Validation nominative rattachée à un ticket	Répond directement à l'exigence EF-21
Création ou modification d'un compte à privilèges	Double validation et revue périodique des droits	Cible privilégiée en cas de compromission
Réinitialisation de mot de passe	Vérification d'identité préalable et trace du valideur	Répond directement à l'exigence EF-09

7.4 Justification des contrôles d'accès retenus

Réponse directe à la demande formulée au chapitre 6 de l'expression des besoins : proposer une solution d'administration sécurisée et justifier les contrôles d'accès retenus.

- **Contrôle par rôle et non par personne.** Les droits sont portés par des groupes, jamais attribués directement à un compte. Un changement de fonction se traduit par un changement de groupe, ce qui rend la revue des droits fiable et auditable.
- **Séparation du périmètre géographique et du périmètre fonctionnel.** Un administrateur d'agence possède les droits fonctionnels d'administration, mais uniquement sur son site. Cela limite fortement l'impact d'une compromission de compte local.
- **Séparation du canal de consultation et du canal d'administration.** Le portail est un outil de consultation et de pilotage : il affiche l'état des équipements, mais n'exécute aucune opération sensible. Ces opérations passent par un canal d'administration restreint, sur un réseau dédié, sans aucune exposition publique.
- **Double validation sur les opérations irréversibles.** Aucune action de nature à couper un service ou à ouvrir un accès ne peut être déclenchée par un compte unique.
- **Traçabilité systématique.** Toute action d'administration produit une entrée de journal avec auteur, date, cible et nature du changement, sans possibilité de désactivation par l'opérateur.
- **Refus par défaut.** Un droit non accordé est un droit refusé, appliqué au niveau réseau autant qu'au niveau applicatif.

À retenir — la cliente demande de distinguer les droits selon les responsabilités et de ne pas exposer les opérations sensibles. La matrice transforme cette intention en règles vérifiables : chaque ligne du tableau 7 sera testée en recette avec un compte du profil correspondant.

8. Choix techniques et justifications

La cliente a demandé à trois reprises que les choix soient comparés puis justifiés. Ce chapitre présente la méthode, les comparatifs et le choix retenu pour chaque brique.

8.1 Méthode de comparaison

Critère	Poids	Ce qui est évalué
Couverture fonctionnelle	30 %	Adéquation réelle au besoin exprimé, sans développement spécifique
Coût et licence	20 %	Coût total sur trois ans, modules et support inclus
Exploitabilité	20 %	Simplicité d'installation, de mise à jour et de sauvegarde
Intégration	20 %	Capacité à s'interfacer avec l'annuaire, le portail et les autres briques
Pérennité	10 %	Activité de l'éditeur ou de la communauté et documentation disponible

8.2 Outil de gestion des tickets (chapitre 5 des besoins)

Tableau 9 — Comparatif des outils de gestion des tickets.

Critère	GLPI	osTicket	Zammad
Couverture fonctionnelle	Très large : tickets, inventaire de parc, base de connaissances, contrats, niveaux de service	Correcte sur les tickets, pas de gestion de parc	Excellente sur le support, orientée service client
Coût	Open source, coût nul hors hébergement	Open source, coût nul	Open source, version communautaire plus limitée
Exploitabilité	Installation éprouvée sur serveur Linux, sauvegarde simple	Très léger, mise en route rapide	Mise à jour plus délicate
Intégration	Annuaire, authentification unique, inventaire par agent, API complète	Annuaire basique, API limitée	Annuaire et API de bonne qualité
Pérennité	Très large communauté francophone, éditeur actif	Communauté active mais projet plus restreint	Éditeur actif, communauté plus réduite

Choix retenu : GLPI

- Il couvre nativement les neuf champs obligatoires exigés par la cliente : numéro de ticket, demandeur, agence, date et heure de création, catégorie, description, priorité, technicien en charge et statut.
- Il conserve l'historique complet des actions jusqu'à la clôture, puis archive le contenu, ce qui répond à l'exigence EF-26.

- Il permet de répondre à la question centrale de la cliente, **qui, quand, sur quel service ou équipement, pour quelle raison et avec quel résultat** : ces cinq informations sont des champs natifs ou des champs de suivi rendus obligatoires.
- Il s'intègre à l'annuaire pour l'authentification et à l'inventaire pour rattacher une intervention à un équipement réel, ce qui est indispensable au croisement entre ticketing, parc et supervision.
- Son API permet au portail d'afficher les tickets du salarié sans double saisie et sans outil supplémentaire.
- Il est disponible en français, ce qui facilite concrètement l'adoption par les techniciens et les salariés.

8.3 Outil de supervision (chapitre 7 des besoins)

Tableau 10 — Comparatif des outils de supervision.

Critère	Zabbix	Centreon	Prometheus et Grafana
Couverture fonctionnelle	Réseau, serveurs et applicatifs, cartes, alertes, tableaux de bord	Réseau et serveurs, très orientée grandes infrastructures	Très efficace sur les métriques applicatives et les conteneurs
Coût	Open source, coût nul	Coût plus élevé en version éditeur, modules payants	Open source, coût nul
Exploitabilité	Exploitation accessible, agent Windows et Linux disponible	Riche mais plus complexe à exploiter	Excellente sur les métriques, moins directe sur le réseau
Intégration	Annuaire, API complète exploitable par le portail, notifications multiples	Intégration forte avec l'écosystème de l'éditeur	API très ouverte, excellente association avec Grafana
Pérennité	Très large communauté internationale	Éditeur français, communauté solide	Écosystème très actif, orienté infrastructure moderne

Choix retenu : Zabbix

- Il couvre exactement les six points demandés par la cliente : indisponibilité d'un serveur ou d'un équipement, coupure du service Web, ruption d'un accès intersite, indisponibilité d'une machine virtuelle, usage processeur, mémoire et disque, et échec d'une sauvegarde. Aucun développement spécifique n'est nécessaire.
- Il supervise indifféremment des serveurs Windows et Linux, des équipements réseau et des hyperviseurs, ce qui correspond à l'hétérogénéité des quatre sites.
- Son API permet au portail d'afficher l'état des services et les alertes sans dupliquer l'information ni ressaisir des données.
- Prometheus associé à Grafana serait plus élégant sur des métriques applicatives, mais moins direct sur la supervision réseau et matérielle. Centreon est plus lourd à exploiter pour une infrastructure de cette taille.

8.4 Solution d'accès distant (chapitre 4 des besoins)

Tableau 11 — Comparatif des solutions d'accès distant.

Critère	Passerelle de session en HTML5 derrière le reverse proxy	Tunnel chiffré avec second facteur	Publication directe des protocoles d'administration
Respect de la contrainte de non-exposition	Total : seul HTTPS sort	Total : aucun port d'administration publié	Non respecté, solution écartée
Confort pour le salarié	Session dans le navigateur, sans installation	Nécessite un client sur le poste utilisateur	Non retenu
Traçabilité	Point unique, journalisation native des sessions	Journalisation par tunnel et par utilisateur	Dispersée
Granularité des droits	Machine virtuelle nominative, par profil	Accès réseau, contrôle plus large	Non maîtrisée
Risque de sécurité	Faible, surface réduite à une seule application	Faible à modéré selon la configuration cliente	Élevé

Choix retenu : approche combinée

- Pour les **salariés**, une passerelle de session accessible en HTTPS, placée derrière le point d'entrée applicatif de la zone exposée, qui ouvre elle-même la session vers la machine virtuelle nominative. Le salarié n'installe rien et ne connaît jamais l'adresse de sa machine.
- Pour les **administrateurs et techniciens nomades**, un tunnel chiffré avec second facteur, donnant accès au réseau d'administration uniquement, avec des règles rattachées au profil.
- Dans les deux cas, **aucun flux d'administration n'est publié sur Internet** et la publication externe se limite au flux applicatif HTTPS, conformément au schéma de référence du SITE B.

8.5 Autres briques retenues

Tableau 12 — Récapitulatif des briques techniques retenues.

Brique	Solution retenue	Justification courte
Annuaire et authentification	Annuaire d'entreprise, groupes par profil et par agence	Source unique de vérité des identités, base du contrôle par rôle
Authentification unique et second facteur	Fédération d'identité avec validation par un second facteur	Évite la duplication des comptes et centralise la politique de sécurité
Base de données du portail	Système de gestion de base de données relationnelle éprouvé	Cohérence des données et sauvegarde maîtrisée
Hébergement du portail	Application Web hébergée en zone exposée, servie par le point d'entrée applicatif	Cohérent avec le schéma réseau de référence
Répartition de charge	Reverse proxy avec terminaison TLS	Point d'entrée unique, seule publication externe, journalisation centralisée
Sauvegarde des machines virtuelles	Solution de sauvegarde dédiée à l'hyperviseur avec vérification d'intégrité	Restauration rapide d'une machine complète

Brique	Solution retenue	Justification courte
Sauvegarde des fichiers et bases	Outil de sauvegarde incrémentale avec déduplication	Respect du RPO de 24 heures, copie externalisée
Automatisation du déploiement	Gestion de configuration et orchestration par rôles	Déploiement reproductible sur les quatre sites, exigence ENF-20
Virtualisation	Hyperviseur de type 1, clusters par site	Socle commun pour les postes virtuels et les services
Collecte des journaux	Collecteur central avec rétention de 12 mois	Répond aux exigences ENF-17 et ENF-18

8.6 Éléments restant à confirmer avant engagement

- La famille exacte des produits de virtualisation et de l'annuaire, si le formateur impose une cible précise (hypothèses H4 et H8).
- Le nom de domaine interne et public, ainsi que l'autorité de certification utilisée.
- Le mode de répartition de charge retenu, applicatif ou réseau, selon les ressources disponibles.
- Le niveau de redondance souhaité sur les sites secondaires, qui a un impact direct sur le coût matériel.

9. Maquette du portail Web

La cliente souhaite valider une maquette visuelle avant tout développement. Ce chapitre décrit l'arborescence, les parcours de navigation et le contenu des écrans. Il constitue la spécification à partir de laquelle la maquette graphique sera produite puis soumise à validation.

À retenir — la maquette graphique elle-même constitue un livrable distinct, à produire et à présenter à la cliente. Ce chapitre en fixe le contenu afin d'éviter les allers-retours.

9.1 Arborescence des écrans

Tableau 13 — Arborescence des écrans du portail, couvrant les dix-sept écrans demandés par la cliente.

N°	Écran	Contenu principal	Profils concernés
1	Accueil	Annonces internes importantes, état simple des services accessibles au salarié	Tous
2	Connexion	Authentification, second facteur, demande de réinitialisation de mot de passe	Tous
3	Espace salarié	Vue d'ensemble personnelle : services, demandes en cours, raccourcis	Tous
4	Mon profil	Nom, prénom, adresse professionnelle, agence, fonction, photo modifiable	Tous
5	Mes services	Liste des services autorisés pour le profil, avec état et accès direct	Tous
6	Ma machine virtuelle	Machine nominative, lancement de session, historique de connexion	Tous
7	Assistance / Tickets	Création, suivi et consultation des demandes selon le profil	Tous
8	Tableau de bord administrateur	État des sites, serveurs, machines virtuelles, accès distants, alertes	Technicien, Admin, Direction
9	Utilisateurs	Comptes, rôles, agences, droits, procédure de réinitialisation	Admin
10	Agences	Sites, effectifs, équipements rattachés, état de disponibilité	Admin, Direction
11	Réseau	VLAN, plans d'adressage, segmentation par site	Technicien, Admin
12	Accès distants et tunnels	Tunnels inter-sites, sessions actives, état des liens	Technicien, Admin
13	Machines virtuelles	Inventaire, état, ressources allouées, actions de gestion	Admin
14	Serveurs	Inventaire, état, services hébergés, indicateurs	Technicien, Admin
15	Supervision	Alertes actives, historique, graphiques de charge, acquittement	Technicien, Admin, Direction

N°	Écran	Contenu principal	Profils concernés
16	Sauvegardes	Jobs, dernier passage, statut, échecs, historiques de restauration	Technicien, Admin
17	Documentation	Procédures d'exploitation, schémas, guides utilisateurs	Tous selon niveau

9.2 Parcours salarié (profil Employé)

- **Connexion** : le salarié ouvre le portail, saisit son identifiant, valide son second facteur et arrive sur l'accueil.
- **Accueil** : il consulte les annonces internes et l'état des services qui le concernent.
- **Mes services** : il lance directement un service autorisé, par exemple l'accès à sa machine virtuelle.
- **Ma machine virtuelle** : le portail recherche la machine qui lui est attribuée et ouvre la session dans le navigateur. Aucune adresse, aucun port, aucun identifiant technique n'est affiché.
- **Besoin d'un nouveau droit** : il crée une demande depuis Assistance / Tickets, choisit la catégorie, précise le service demandé et la justification. Il suit ensuite l'avancement de sa demande depuis le même écran.
- **Mot de passe oublié** : il déclenche une demande de réinitialisation depuis l'écran de connexion, sans contacter l'assistance par un autre canal.

9.3 Parcours technicien

- **Tableau de bord** : le technicien voit l'état de son site et les alertes actives.
- **File de tickets** : il consulte les demandes de son périmètre, les prend en charge, les catégorise et les priorise.
- **Diagnostic** : il consulte l'inventaire, l'état des serveurs et les graphiques de supervision en lecture.
- **Intervention** : il saisit le compte rendu, l'équipement concerné, la cause identifiée et le résultat. Ces informations alimentent l'exigence EF-27.
- **Clôture** : le ticket passe en statut clôturé, l'historique reste consultable en lecture seule.

9.4 Parcours administrateur

- **Tableau de bord global** : état des quatre sites, serveurs, machines virtuelles, tunnels et alertes principales.
- **Constat et décision** : l'administrateur identifie la cible concernée puis décide de l'action à mener.
- **Action encadrée** : pour une opération sensible, l'action est menée depuis le canal d'administration restreint, avec double validation et journalisation. Le portail affiche l'état, il n'exécute pas l'action.
- **Droit supplémentaire** : l'administrateur reçoit la demande de droit, valide ou refuse en motivant sa décision, et l'ouverture du droit est rattachée au ticket.
- **Réinitialisation de mot de passe** : il vérifie l'identité du demandeur, procède à la réinitialisation selon la procédure et l'opération est tracée au dossier du ticket.
- **Gestion des agences** : il crée ou modifie les profils d'accès liés à chaque agence, sans jamais attribuer un droit directement à une personne.

9.5 Différenciation des espaces selon le profil

C'est une demande explicite de la cliente. Pour un même écran, le contenu et les actions disponibles varient :

Tableau 14 — Différenciation des espaces selon le profil.

Écran	Espace salarié	Espace technicien	Espace administrateur
Tableau de bord	Aucun accès	État de son site et alertes	Vue des quatre sites, tous

Écran	Espace salarié	Espace technicien	Espace administrateur
		actives	indicateurs
Tickets	Ses demandes uniquement	File complète de son site, traitement et affectation	Toutes les demandes, indicateurs, réaffectation
Machines virtuelles	Sa machine, lancement de session	Consultation de son périmètre	Inventaire complet, actions de gestion
Utilisateurs	Aucun accès	Lecture limitée	Création, modification des droits, réinitialisation
Supervision	Aucun accès	Consultation et diagnostic	Consultation, acquittement, paramétrage des seuils
Sauvegardes	Aucun accès	Consultation des statuts	Lancement, restauration, planification

9.6 Exemples d'écrans attendus dans la maquette

- **Tableau de bord administrateur** : bandeau d'indicateurs par site, liste des alertes actives triées par sévérité, état des tunnels entre sites, dernières sauvegardes.
- **Création d'un ticket** : formulaire réduit au strict nécessaire, avec catégorie, priorité, description et agence pré-remplie depuis le profil de l'utilisateur.
- **Suivi d'une demande** : frise de progression, statut, technicien en charge, historique des actions.
- **Accès à une machine virtuelle** : carte nominative unique, bouton de lancement, mention explicite des conditions de sécurité, historique des dernières sessions.
- **Supervision** : vue synthétique du parc, code couleur par sévérité, accès au graphique de charge par équipement.

9.7 Règles d'interface

- Toute fonction non autorisée pour le profil est absente du menu et de l'interface, mais reste interdite côté serveur.
- Aucune information technique interne n'apparaît dans les messages d'erreur destinés au salarié.
- Les actions destructrices demandent une confirmation explicite rappelant la cible et l'effet attendu.
- Les écrans d'état utilisent un code couleur unique et cohérent sur l'ensemble du portail.

10. Sécurité, journalisation et traçabilité

Ce chapitre regroupe les dispositions transverses qui découlent des exigences exprimées et des contraintes du projet.

10.1 Mesures de sécurité structurantes

- **Surface d'exposition réduite** : une seule publication externe, HTTPS en 443, vers le point d'entrée applicatif.
- **Authentification forte** : second facteur obligatoire pour tous les accès distants, sans exception ni contournement.
- **Segmentation** : un réseau par usage et un réseau d'administration isolé, avec refus par défaut entre zones.
- **Cloisonnement des sessions** : une session vers une machine virtuelle s'arrête à cette machine. Aucun rebond vers un autre serveur ou un équipement d'administration.
- **Durcissement** : composants exposés réduits à leur strict rôle, services inutiles désactivés, mises à jour suivies.
- **Gestion des secrets** : comptes de service dédiés, secrets centralisés, aucune valeur en clair dans un dépôt ou un fichier de configuration.
- **Certificats** : TLS valide sur le point d'entrée, renouvellement automatisé, contrôle de l'expiration par la supervision.

10.2 Journalisation

Tableau 15 — Journalisation et durées de conservation (hypothèse H7).

Événement	Données enregistrées	Conservation
Connexion au portail	Identité, date et heure, adresse source, résultat de l'authentification	12 mois
Validation du second facteur	Identité, date et heure, méthode utilisée, succès ou échec	12 mois
Ouverture d'une session distante	Identité, machine cible, date et heure de début, durée, adresse source	12 mois
Création et traitement d'un ticket	Auteur, date, intervention, technicien, résultat	Durée du ticket puis archivage
Modification d'un droit	Auteur, date, bénéficiaire, droit ajouté ou retiré, motif, ticket de rattachement	12 mois
Action d'administration	Opérateur, date, cible, nature du changement, valideur secondaire	12 mois
Échec de sauvegarde	Job concerné, date, cause de l'échec	12 mois
Refus d'accès	Identité ou source, ressource visée, date et heure	12 mois

10.3 Anticipation des usages abusifs

Tableau 16 — Risques et mesures de protection associées.

Risque identifié	Mesure prévue
Tentative de connexion à une machine virtuelle non attribuée	Contrôle serveur de l'attribution nominative, refus et journalisation de la tentative
Élévation de privilèges depuis le portail	Contrôle des droits à chaque requête, refus de toute modification de rôle par l'utilisateur lui-même
Vol de session après authentification	Durée de session limitée, second facteur, invalidation de session à la déconnexion
Utilisation d'un compte administrateur depuis un poste non maîtrisé	Restriction des sources autorisées pour l'administration et second facteur
Attaque par force brute sur l'écran de connexion	Limitation du nombre de tentatives, temporisation et alerte de supervision
Utilisation abusive du lien entre portail et annuaire	Compte de service dédié, droits minimaux, journalisation des requêtes

10.4 Protection des données personnelles

- Le portail n'affiche à un salarié que ses propres informations et celles strictement nécessaires à son activité.
- Les champs du profil exposés en lecture aux autres profils sont limités au minimum utile et arbitrés avec la cliente.
- Les journaux ne contiennent pas de données sensibles au-delà de ce qui est nécessaire à la traçabilité.
- Les durées de conservation sont fixées et respectées par le collecteur de journaux.

11. Recette et critères d'acceptation

La recette est conduite exigence par exigence, sur la base des critères d'acceptation du chapitre 4. Les tests structurants sont listés ci-dessous. Un test non concluant bloque la recette du lot concerné.

11.1 Tests fonctionnels

N°	Test	Résultat attendu	Exigences couvertes
T01	Connexion d'un Employé et affichage de l'accueil	Annonces et état des services de son périmètre uniquement	EF-01, EF-02
T02	Connexion d'un Administrateur global	Tableau de bord des quatre sites avec alertes actives	EF-03, EF-31
T03	Modification de sa photo par un Employé	Modification acceptée et visible après reconnexion	EF-06
T04	Tentative de modification de son propre rôle par un Employé	Refus côté serveur et journalisation de la tentative	EF-07
T05	Demande de réinitialisation de mot de passe	Ticket créé, horodaté, avec statut de traitement	EF-08, EF-09
T06	Accès direct à une URL d'administration avec un compte Employé	Refus, redirection et journalisation, y compris sur l'API	EF-13
T07	Connexion distante d'un salarié à son poste virtuel	Session ouverte dans le navigateur après second facteur	EF-17, EF-18
T08	Connexion distante sans second facteur	Refus avant toute ouverture de session	EF-18, ENF-03
T09	Tentative d'accès à la machine virtuelle d'un collègue	Refus et entrée de journal	EF-17
T10	Scan externe des ports depuis Internet	Seul le port 443 applicatif répond ; aucun port RDP ou SSH accessible	ENF-01, ENF-02
T11	Tentative d'accès depuis un poste virtuel vers un serveur interne non autorisé	Refus du flux et journalisation	EF-19, EF-20
T12	Demande de droit supplémentaire par un salarié	Droit inactif jusqu'à validation nominative par un administrateur	EF-21, EF-22
T13	Modification d'un droit par un administrateur	Entrée de journal avec auteur, date, cible et motif	EF-23
T14	Création d'un ticket et vérification des champs	Les neuf champs obligatoires sont présents et non vides	EF-25
T15	Recherche d'un ticket clôturé	Qui, quand, sur quel équipement, pourquoi et avec quel résultat	EF-27

N°	Test	Résultat attendu	Exigences couvertes
T16	Suivi d'une demande par son demandeur	Statut et dernière action visibles	EF-28
T17	Connexion d'un administrateur d'agence	Aucun accès effectif aux données des autres sites	EF-30
T18	Consultation de l'état des équipements depuis le portail	Données issues de la supervision, à jour	EF-32
T19	Tentative d'action sensible depuis une page publique	Impossible : aucune action n'est exécutable depuis le portail	EF-33

11.2 Tests de supervision

N°	Test	Résultat attendu	Exigences couvertes
T20	Arrêt d'un serveur supervisé	Alerte émise en moins de 5 minutes	EF-35, ENF-12
T21	Arrêt volontaire du service Web	Alerte dédiée et état visible sur le portail	EF-36
T22	Coupure d'un tunnel inter-sites	Alerte de niveau élevé	EF-37
T23	Arrêt non planifié d'une machine virtuelle	Alerte dédiée	EF-38
T24	Charge processeur ou saturation disque simulée	Valeurs remontées, historisées et affichées en graphique	EF-39
T25	Échec provoqué d'une sauvegarde	Alerte générée et état en échec visible depuis le portail	EF-40
T26	Consultation des quatre rubriques d'information	Infrastructure, sauvegardes, incidents et documentation accessibles	EF-41

11.3 Tests de sécurité et de reprise

N°	Test	Résultat attendu
T27	Restauration d'une machine virtuelle depuis une sauvegarde	Restauration fonctionnelle et documentée, délai conforme au RTO
T28	Rupture d'un composant applicatif exposé	Le service reste disponible via l'instance restante
T29	Revue des journaux du collecteur central	Tous les événements du tableau 15 présents et horodatés de façon cohérente
T30	Déploiement d'un composant depuis le dépôt automatisé	Déploiement reproductible sans intervention manuelle

11.4 Modalités de validation

- La recette est conduite par l'équipe projet en présence d'un représentant de la cliente.
- Chaque test donne lieu à un résultat consigné : conforme, conforme avec réserve, ou non conforme.
- Un test non conforme bloque la recette du lot concerné et déclenche une correction puis un nouveau passage.
- La validation finale est prononcée après passage de l'ensemble des tests et remise de la documentation d'exploitation.

12. Planning prévisionnel et lots

Le projet est découpé en lots afin de permettre une validation progressive et de limiter les risques. Les durées sont exprimées en semaines de travail et restent indicatives jusqu'à validation du planning définitif.

12.1 Découpage en lots

Tableau 17 — Découpage prévisionnel en lots. Durée totale indicative : environ quinze semaines.

Lot	Contenu	Durée	Livrable de fin de lot
Lot 0 — Cadrage	Validation du cahier des charges, de l'architecture et de la maquette	1 semaine	Cahier des charges, architecture et maquette validés
Lot 1 — Socle réseau	Adressage, découpage en VLAN, routage inter-sites, filtrage, interconnexion des sites	2 semaines	Infrastructure réseau opérationnelle et documentée
Lot 2 — Identités	Annuaire, groupes par profil et par agence, second facteur, authentification unique	1,5 semaine	Annuaire et politique d'authentification en service
Lot 3 — Zone exposée	Hébergement du portail, point d'entrée applicatif, certificats, répartition de charge	1,5 semaine	Portail accessible en HTTPS depuis l'extérieur
Lot 4 — Portail	Développement ou paramétrage des écrans, contrôle des droits, intégrations	3 semaines	Portail fonctionnel conforme à la maquette validée
Lot 5 — Accès distant	Passerelle de session, attribution nominative des machines virtuelles, journalisation	1,5 semaine	Accès distant opérationnel sans exposition de RDP ou SSH
Lot 6 — Assistance	Outil de ticketing, champs obligatoires, workflows, base de connaissances	1,5 semaine	Gestion des demandes opérationnelle et tracée
Lot 7 — Supervision	Supervision des quatre sites, alertes, tableaux de bord, remontée des sauvegardes	1,5 semaine	Supervision centralisée opérationnelle
Lot 8 — Sauvegardes	Politique de sauvegarde, externalisation, test de restauration documenté	1 semaine	Sauvegardes en place et restauration testée
Lot 9 — Documentation et recette	Documentation d'exploitation, procédures, recette complète, durcissement	1,5 semaine	Documentation livrée, recette prononcée

12.2 Chemin critique et points de vigilance

- La **validation de la maquette** est un prérequis bloquant : aucun développement ne débute sans elle, conformément à la demande de la cliente.
- Le **plan d'adressage des sites A, C et D** doit être figé avant le lot 1, sous peine de reprise des règles de filtrage.
- La **politique de droits** doit être validée avant le lot 4, car elle conditionne le développement des écrans.

- Le **test de restauration** ne doit pas être reporté en fin de projet : il valide la stratégie de sauvegarde choisie (ENF-16).
- La **documentation** est produite au fil des lots, jamais en fin de projet.

13. Points soumis à validation de la cliente

Conformément à la demande formulée par la cliente, les éléments suivants doivent être validés avant tout début de réalisation. Ce chapitre constitue la synthèse des points à arbitrer.

13.1 Éléments à valider

Tableau 18 — Points soumis à validation avant réalisation.

N°	Élément soumis à validation	Décision attendue
V1	Cahier des charges fonctionnel et technique dans son ensemble	Validation ou demandes de modification
V2	Architecture technique proposée au chapitre 6	Validation, notamment de la chaîne d'accès distant
V3	Matrice des droits du chapitre 7	Validation profil par profil
V4	Maquette visuelle du portail et parcours de navigation	Validation avant démarrage du développement
V5	Choix de l'outil de gestion des tickets	Validation du choix et de la justification
V6	Choix de l'outil de supervision	Validation du choix et de la justification
V7	Hypothèses de travail du chapitre 1.4	Confirmation, correction ou invalidation
V8	Plan d'adressage des sites A, C et D	Fourniture du plan réel ou validation de la logique proposée
V9	Objectifs de reprise, RPO et RTO	Confirmation des valeurs retenues
V10	Planning et découpage en lots	Validation du calendrier et du périmètre de chaque lot

13.2 Questions ouvertes

- Le nombre exact de salariés par site et le dimensionnement des postes virtuels attendus.
- La liste des applications métier dont l'accès doit être proposé depuis le portail, au-delà de la machine virtuelle.
- Le niveau de service attendu en dehors des heures ouvrées.
- L'existence d'obligations réglementaires ou contractuelles particulières susceptibles d'imposer des choix techniques.
- Le mode de gestion des comptes des intervenants extérieurs, s'il en existe.

À retenir — ces points n'empêchent pas le démarrage du lot 0 mais doivent être levés avant le lot 4.

14. Annexes

Annexe A — Lexique

Terme	Définition
VLAN	Réseau local virtuel : découpage logique d'un réseau physique en domaines séparés, ici par usage.
DMZ	Zone démilitarisée : segment réseau isolé destiné à héberger les composants exposés à Internet.
Reverse proxy	Service qui reçoit les requêtes depuis l'extérieur et les transmet aux serveurs applicatifs internes. Point d'entrée unique du projet.
MFA	Authentification multifacteur : validation de l'identité par un second élément en plus du mot de passe.
RDP / SSH	Protocoles d'administration et de prise en main à distance. Ils ne doivent jamais être publiés sur Internet dans ce projet.
Passerelle de session	Service qui ouvre lui-même la session vers une machine cible et la restitue dans un navigateur, sans exposer le protocole.
RPO	Perte de données maximale acceptable, exprimée en durée.
RTO	Durée maximale d'interruption acceptée avant restauration du service.
RBAC	Contrôle d'accès fondé sur les rôles : les droits sont portés par des groupes, pas par des individus.
Moindre privilège	Principe consistant à n'accorder que les droits strictement nécessaires à l'activité.
Refus par défaut	Tout flux ou accès non explicitement autorisé est refusé.
Hyperviseur	Couche logicielle permettant d'exécuter plusieurs machines virtuelles sur un serveur physique.
IaaS	Infrastructure décrite sous forme de code, déployée de manière reproductible depuis un dépôt.
Acquittement d'alerte	Action par laquelle un opérateur signale qu'il a pris connaissance d'une alerte.

Annexe B — Synthèse des exigences

Tableau 19 — Synthèse : 46 exigences fonctionnelles et 27 exigences non fonctionnelles.

Domaine	Exigences	Nombre	Priorité dominante
Accueil et état des services	EF-01 à EF-04	4	Impérative
Profil et mots de passe	EF-05 à EF-10	6	Impérative
Ressources et droits d'accès	EF-11 à EF-16	6	Impérative

Domaine	Exigences	Nombre	Priorité dominante
Machines virtuelles et travail à distance	EF-17 à EF-23	7	Impérative
Assistance et tickets	EF-24 à EF-29	6	Impérative
Périmètre des administrateurs	EF-30 à EF-34	5	Impérative
Supervision et documentation	EF-35 à EF-42	8	Impérative
Portail Web et maquette	EF-43 à EF-46	4	Impérative
Exigences non fonctionnelles	ENF-01 à ENF-27	27	Mixte

Annexe C — Matrice des flux détaillée

Tableau 20 — Matrice des flux. Tout flux non listé est refusé.

N°	Source	Destination	Flux	Décision
F01	Internet	Point d'entrée applicatif	HTTPS 443	Autorisé
F02	Internet	Tous autres composants	Tout	Refusé
F03	Point d'entrée applicatif	Serveurs applicatifs	Ports applicatifs retenus	Autorisé
F04	Zone exposée	Réseau interne	Nouvelles sessions	Refusé
F05	Réseau interne	Zone exposée	Requêtes applicatives	Autorisé
F06	Zone exposée	Internet	HTTPS, DNS, NTP	Autorisé selon règles
F07	Passerelle de session	Machines virtuelles nominatives	Ports applicatifs	Autorisé, cible nominative
F08	Postes virtuels	Services internes autorisés	Ports applicatifs du profil	Autorisé
F09	Postes virtuels	Autres serveurs et équipements	Tout	Refusé
F10	Réseau utilisateur	Réseau d'administration	Tout	Refusé
F11	Réseau d'administration	Équipements et hyperviseurs	Protocoles d'administration chiffrés	Autorisé, sources déclarées
F12	Sites secondaires	Site principal	Flux applicatifs nécessaires	Autorisé via tunnel chiffré
F13	Serveurs	Collecteur de journaux	Journaux système	Autorisé
F14	Serveurs	Système de sauvegarde	Flux de sauvegarde	Autorisé
F15	Supervision	Ensemble du parc	Sondes agent et réseau	Autorisé
F16	VLAN Wi-Fi visiteurs	Réseau interne	Tout	Refusé, hormis accès Internet

Annexe D — Écarts entre la demande initiale et la proposition

Tableau 21 — Arbitrages proposés par rapport à la demande initiale.

Point de la demande	Proposition de l'équipe projet	Motif
Accès distant sans exposer RDP ou SSH	Passerelle de session en HTTPS plutôt que publication de protocole	Répond à la contrainte en supprimant toute exposition directe
Actions d'administration sur pare-feu, commutateurs et hyperviseurs	Réalisées hors du portail, sur un canal d'administration restreint	Le portail reste un outil de pilotage, pas d'exécution
Suivi des demandes par le salarié	Reprise automatique des tickets dans le portail plutôt que double saisie	Évite la ressaisie et les incohérences entre deux outils
Documentation technique accessible	Publication d'une base de connaissances issue de l'outil d'assistance	Un seul endroit à maintenir, cohérence garantie
État des équipements présenté dans le portail	Données récupérées depuis l'outil de supervision	Aucune saisie manuelle, information toujours à jour

Annexe E — Validation

Le présent cahier des charges, l'architecture technique et la maquette du portail sont soumis à la validation de la cliente avant tout début de réalisation.

Pour l'équipe projet	Pour la cliente
N	O
N	O

Fin du document.